



STUDIO SHODWE

# VULNERABILITY ASSESSMENT REPORT

## SERVICES



Target:  
zero.webappsecurity.com



Assessed By: Xhanti



CIN: FIT/APR26/CS8004



Date: 26 May 2026



[www.reallygreatsite.com](http://www.reallygreatsite.com)



# INTRODUCTION

This report presents the findings of a vulnerability assessment conducted on [zero.webappsecurity.com](https://zero.webappsecurity.com), a demo banking web application.

The assessment was performed using:

- Nmap (Network Port Scanner)
- Browser DevTools (Chrome/Edge)

Objective:

To identify security weaknesses, classify their risk level, and provide remediation recommendations.

Assessed By: Xhanti

CIN: FIT/APR26/CS8004

Date: 26 May 2026

# NMAP SCAN RESULTS

Target IP: 54.82.22.214

Target: zero.webappsecurity.com

Scan Tool: Nmap 7.80

| PORT     | STATE    | SERVICE | RISK   |
|----------|----------|---------|--------|
| 21/tcp   | filtered | FTP     | Medium |
| 22/tcp   | filtered | SSH     | Medium |
| 23/tcp   | filtered | Telnet  | HIGH   |
| 80/tcp   | open     | HTTP    | Medium |
| 110/tcp  | filtered | POP3    | Low    |
| 143/tcp  | filtered | IMAP    | Low    |
| 443/tcp  | open     | HTTPS   | Low    |
| 3389/tcp | filtered | RDP     | HIGH   |

# BROWSER DEVTOOLS FINDINGS

Target: zero.webappsecurity.com

Tool: Microsoft Edge DevTools

## MISSING SECURITY HEADERS:

✗ Content-Security-Policy – HIGH

Allows cross-site scripting (XSS) attacks

✗ X-Frame-Options – MEDIUM

Site can be embedded in iframes (Clickjacking)

✗ X-XSS-Protection – MEDIUM

No built-in XSS protection header

✗ Strict-Transport-Security – HIGH

Server does not force HTTPS connections

## DETECTED ISSUES:

⚠ HTTP Not Secure (Port 80 open) – HIGH

Data transmitted without encryption

⚠ Access-Control-Allow-Origin: \* – HIGH

Any external website can access site resources

# RISK SUMMARY

Total Vulnerabilities Found: 9

## HIGH RISK – 4

- HTTP without HTTPS (Port 80 open)
  - Missing Content-Security-Policy header
  - Missing Strict-Transport-Security header
  - Access-Control-Allow-Origin: \*

## MEDIUM RISK – 3

- Telnet Port 23 present
- Missing X-Frame-Options header
- Missing X-XSS-Protection header

## LOW RISK – 2

- FTP Port 21 filtered
- SSH Port 22 filtered

## RECOMMENDATIONS

### 1. Enable HTTPS (HIGH)

Force all traffic through HTTPS.

Fix: Install SSL certificate and redirect HTTP to HTTPS.

### 2. Add Content-Security-Policy Header (HIGH)

Prevents XSS attacks.

Fix: Add CSP header in server configuration.

### 3. Add Strict-Transport-Security Header (HIGH)

Forces browsers to use HTTPS only.

Fix: Add HSTS header with max-age=31536000.

### 4. Fix Access-Control-Allow-Origin (HIGH)

Restrict which domains can access resources.

Fix: Replace \* with specific trusted domains.

### 5. Add X-Frame-Options Header (MEDIUM)

Prevents clickjacking attacks.

Fix: Set X-Frame-Options: DENY or SAMEORIGIN.

### 6. Add X-XSS-Protection Header (MEDIUM)

Enables browser XSS filtering.

Fix: Set X-XSS-Protection: 1; mode=block.

### 7. Disable Telnet Port 23 (HIGH)

Old insecure protocol.

Fix: Disable completely, use SSH instead.

# CONCLUSION

This vulnerability assessment of zero.webappsecurity.com identified 9 security weaknesses across network and web application layers.

## Key Findings:

- 4 High Risk vulnerabilities requiring immediate action
- 3 Medium Risk vulnerabilities to be addressed soon
- 2 Low Risk vulnerabilities to monitor

The most critical issues are the lack of HTTPS enforcement, missing security headers, and the open Access-Control-Allow-Origin policy.

Immediate action is recommended to protect user data and prevent potential attacks.

Assessed By: Xhanti

CIN: FIT/APR26/CS8004

Date: 26 May 2026

Program: Future Interns — Cyber Security